LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING

Siemens SIMATIC IoT2050 CVE-2026-58115 Active Exploitation Daily Priority

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-11-11
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

Published: 2026-11-11 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Aviation and Aerospace Sector Impact
6. Attack Scenarios
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

Siemens SIMATIC IoT2050 CVE-2026-58115 Active Exploitation Daily Priority

1. Executive Summary

CVE-2026-58115 is a critical missing-authentication vulnerability in Node-RED installations on Siemens SIMATIC IoT2050 Advanced devices running Industrial OS. Public product and vulnerability records identify affected devices as all versions before V4.3.4.1 where Node-RED is installed. The defect can permit an unauthenticated remote party to execute code with maximum privileges through the Node-RED HTTP interface.

Current reporting indicates observed exploitation. Treat the report as an urgent exposure-management and incident-hunting priority, not evidence that every appliance is internet-facing or compromised. Inventory and isolate affected appliances, upgrade to the fixed version, and investigate management-plane access and Node-RED flow changes.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-58115
Product / component	Siemens SIMATIC IoT2050 Advanced, Industrial OS with Node-RED installed
Weakness	CWE-306: missing authentication for critical function
Severity	Critical; public reporting describes CVSS 10.0
Affected versions	All versions before V4.3.4.1 with Node-RED installed
Fixed version	V4.3.4.1 or later, per public vulnerability records
Exploitation status	Public reporting describes exploitation; validate environment-specific indicators before declaring compromise

3. Source Review & Confidence

Source	Contribution	Confidence
Siemens ProductCERT SSA-834709	Vendor advisory reference for affected product and remediation	High
NVD CVE-2026-58115	CVE record and canonical reference chain	High
Rapid7 CVE database	Affected-version statement and weakness context	High
SecurityWeek reporting	Defender context on exploitation reporting	Medium
The Hacker News reporting	Supporting public exploitation coverage	Medium

The product/version scope is corroborated by the NVD and Rapid7 records. The exploitation assertion is based on reputable secondary reporting and should be validated against Siemens advisory updates, edge telemetry, and local incident evidence. No reviewed source proves impact to a particular aviation, airport, or aerospace deployment.

4. Vulnerability Details

The affected Node-RED HTTP interface lacks required authentication in the identified configuration. A reachable unauthenticated interface can provide an attacker code-execution capability on the appliance. Exposure depends on whether Node-RED is installed and whether its HTTP service is reachable directly, through a management network, or through an unintended routing/NAT path.

5. Aviation and Aerospace Sector Impact

Sector segment	Operational relevance	Likely exposure path	Defender action
Airport and airline OT integration	Edge gateways may bridge building, baggage, fuel, or facilities telemetry	Flat OT networks, remote support, or exposed management ports	Isolate gateways and validate inbound ACLs
Aerospace manufacturing	Industrial gateways can link production assets and engineering networks	Vendor remote access or unmanaged Node-RED instances	Inventory images and require supplier attestation
MRO and ground support	Maintenance networks may include portable or shared edge devices	Temporary service access and weak segmentation	Remove unused Node-RED and limit admin paths
Defense/space ground operations	Remote-edge devices can affect availability of supporting telemetry	Partner-connected management networks	Apply allowlists and test recovery procedures

Sector relevance is based on the appliance's industrial/edge role; it is not a claim that a particular aviation system uses the affected product.

6. Attack Scenarios

Scenario	Preconditions	Defender focus
Direct HTTP exploitation	Node-RED service is reachable from an untrusted network	Block access, patch, retain proxy/firewall logs
Lateral movement from IT	An attacker reaches the OT management subnet	Enforce segmentation and monitor new internal connections
Remote-support abuse	Third-party access reaches an exposed gateway	Review VPN/jump-host sessions and vendor accounts

7. Affected Products and Exposure

Exposure pattern	Why it matters	Priority
IoT2050 Advanced below V4.3.4.1 with Node-RED reachable	Critical unauthenticated execution path	Critical
Device with Node-RED installed but segmented	Reduced external reachability; lateral risk remains	High
Device without Node-RED installed	Vulnerability condition is not present	Verify
Upgraded and access-restricted device	Confirm version and review historical exposure	Medium

8. Mitigation and Workarounds

1. Identify all SIMATIC IoT2050 Advanced appliances, Industrial OS versions, Node-RED installations, listening services, and owners.
2. Upgrade affected devices to V4.3.4.1 or later using authorized Siemens maintenance procedures and operational change control.
3. Restrict Node-RED HTTP access to named administrative hosts; remove public exposure, default routes, and unnecessary port forwards.
4. Segment IT, OT, vendor-access, and safety-relevant networks; require jump-host mediated administration.
5. Preserve firewall, proxy, VPN, and Node-RED artifacts before remediation where compromise is plausible.

9. Detection Engineering

Signal	Telemetry source	Analytic goal
New connections to Node-RED HTTP ports	Firewall, NetFlow, proxy	Identify unexpected management-plane reachability
Node-RED process/service restart or flow change	Appliance, syslog, configuration management	Identify exploitation aftermath or unauthorized changes
Vendor remote-access session followed by gateway activity	VPN and jump-host logs	Triage third-party access pivots

```
// Replace the port list with ports confirmed for the local Node-RED deployment.
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (1880, 80, 443)
| where InitiatingProcessFileName has_any ("node", "node-red")
| project Timestamp, DeviceName, InitiatingProcessFileName, RemoteIP, RemotePort, RemoteUrl
| order by Timestamp desc
```

10. Threat Hunting

Hypothesis: an exposed or laterally reachable IoT2050 Node-RED service was contacted from an unauthorized source, followed by administrative or configuration activity.

```
index=network earliest=-30d (dest_port=1880 OR dest_port=80 OR dest_port=443)
| stats values(src_ip) as sources count by dest_ip, dest_port
| where count > 0
| sort - count
```

Triage hits by asset ownership, whether the destination is an IoT2050/Node-RED host, source-network authorization, and correlated VPN or maintenance windows.

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / rationale
T1190	Exploit Public-Facing Application	Applicable when the Node-RED interface is publicly reachable; not proof of a specific incident
T1078	Valid Accounts	Consider during remote-support investigation; not CVE-specific evidence

12. Validation / Lab Testing

No exploit was executed. Validation for this report consisted of source review and detection/hunt construction. Operators should validate version, Node-RED installation, listening interfaces, segmentation, and upgrade behavior in an authorized maintenance environment.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	OT/ICS owner	Identify affected devices and eliminate untrusted HTTP reachability immediately
Critical	Platform owner	Upgrade qualifying devices to V4.3.4.1 or later
High	SOC / IR	Hunt historical gateway access and configuration changes
High	Aviation/aerospace supplier management	Obtain component/version attestation from integrators and MRO partners

14. References

- https://nvd.nist.gov/vuln/detail/CVE-2026-58115
- https://cert-portal.siemens.com/productcert/html/ssa-834709.html
- https://www.rapid7.com/db/vulnerabilities/cve-2026-58115/
- https://www.securityweek.com/critical-node-red-flaw-exploited-in-attacks/
- https://thehackernews.com/2026/11/attackers-exploit-critical-siemens.html